TECNOLOGÍA WEB I

GUÍA INTEGRAL DE LA ACTIVIDAD 3

Laboratorios 10 y 11: TELNET, SSH endurecido, SFTP, Fail2ban y túneles

Manual para Windows/PowerShell y entornos de laboratorio Docker/Ubuntu.

Cómo usar esta guía

La Actividad 3 integra los laboratorios 10 y 11. En el Lab 10 se compara TELNET con SSH usando capturas reales, se verifica la identidad del servidor, se configura acceso con clave ed25519 y se publica un archivo con scp. En el Lab 11 se endurece SSH, se restringe una cuenta a SFTP, se demuestra el bloqueo automático de Fail2ban con nftables y se prueba un túnel hacia un servicio interno.

1. Qué se debe entregar

Parte	Resultado esperado	Evidencia
Lab 10	Verificador 11/11; clave ed25519; transferencia scp; TELNET desactivado.	Capturas PCAP/Wireshark, conexión por alias horizonte, archivo publicado y salida 11/11.
Lab 11	Verificador 15/15; SSH endurecido; SFTP enjaulado; Fail2ban/nftables; túnel.	Salida 15/15, sshd -T, prueba SFTP, Ban/Unban, set nftables y respuesta /eco.
Documentación	HOJA_TRABAJO.md y BITACORA_IA.md completas.	Explicación propia de decisiones, pruebas y correcciones.

2. Preparación del entorno

2.1. Reglas de seguridad

- Realiza pruebas únicamente contra las máquinas y contenedores del curso, nunca contra servidores ajenos.
- No pegues claves privadas ni credenciales reales en la IA, capturas o repositorios. La clave privada permanece en el cliente.
- Antes de modificar sshd, mantén dos sesiones administrativas abiertas para tener una vía de recuperación.
- No aceptes una huella de host cambiada sin verificarla por un canal confiable.
- TELNET se activa solo para la captura controlada del Lab 10 y debe desactivarse al terminar.
- En PowerShell, los comandos Linux se ejecutan dentro del contenedor con docker exec; no confundas la consola de Windows con la terminal Linux.

2.2. Crear carpeta de evidencias

PowerShell de Windows

```
New-Item -ItemType Directory -Force C:\TW1\evidencias\Actividad3 | Out-Null
docker ps --format "table {{.Names}}\t{{.Status}}" |
  Tee-Object -FilePath C:\TW1\evidencias\Actividad3\00_contenedores.txt
```

Si el proyecto está en otra ruta, adapta C:\TW1. Guarda las salidas de texto y toma capturas auténticas con Win+Shift+S. No uses una salida de ejemplo como si fuera una ejecución propia.

2.3. Identificar contenedores y archivos

```
docker ps --format "table {{.Names}}\t{{.Status}}"
docker exec -it <NOMBRE_CONTENEDOR_LAB10_O_LAB11> bash
find / -name verificar_lab10.sh -o -name verificar_lab11.sh 2>/dev/null
```

Reemplazo necesario
Sustituye el nombre entre < > por el nombre real que muestra docker ps. Los nombres de contenedor y las rutas internas pueden variar según el compose.

3. Laboratorio 10 — TELNET vs SSH

Objetivo: demostrar que TELNET expone el contenido de la sesión y SSH lo cifra; regenerar claves de host clonadas; crear y autorizar una clave ed25519; conectarse mediante el alias horizonte y publicar comunicado.html por scp.

3.1. Auditoría inicial

```
sudo -i
cd ~/lab10
ssh -V
ss -tlnp | grep -E ':22|:23'
```

Registra la versión de OpenSSH y qué puertos están escuchando. Que TELNET esté inicialmente desactivado en Ubuntu 24.04 es normal.

3.2. Capturas controladas

```
bash telnet_laboratorio.sh activar
bash capturar.sh telnet
bash capturar.sh ssh
```

Los scripts crean datos temporales de prueba y guardan resultados en resultados/. Usa solo las credenciales de demostración de la guía y nunca reutilices contraseñas reales.

Aspecto	TELNET (23)	SSH (22)
Usuario y contraseña	Pueden leerse en claro en la captura.	No deben aparecer como texto de la sesión.
Contenido escrito	Puede verse en claro.	Va cifrado; puede verse el banner de versión.
Conclusión	No usar para administración en redes no confiables.	Usar SSH con verificación de identidad y claves.

3.3. Inspeccionar PCAP en Wireshark

- Abre resultados/telnet.pcap en Wireshark.
- Selecciona un paquete de la sesión y usa Analizar → Seguir → Flujo TCP.
- Identifica usuario, contraseña y texto de prueba visibles en claro; captura la pantalla sin información personal ajena.
- Abre resultados/ssh.pcap y verifica que no se lea la contraseña ni el contenido de la sesión en claro.
- Completa la tabla comparativa en HOJA_TRABAJO.md y guarda las capturas en la carpeta de evidencias.

3.4. Regenerar identidad del servidor

Las claves de host copiadas dentro de una imagen pueden hacer que muchos contenedores o VM compartan la misma identidad. Completa el TODO 1 de preparar_ssh.sh y verifica la nueva huella.

```
ssh-keygen -lf /etc/ssh/ssh_host_ed25519_key.pub
bash preparar_ssh.sh <usuario_admin>
ssh-keygen -lf /etc/ssh/ssh_host_ed25519_key.pub
```

Aviso de host cambiado
REMOTE HOST IDENTIFICATION HAS CHANGED puede deberse a una regeneración prevista o a un ataque de intermediario. Comprueba la huella por un canal confiable antes de actualizar known_hosts; no borres la advertencia a ciegas.

3.5. Clave ed25519, permisos y alias

```
ssh-keygen -t ed25519 -a 64 -C "admin-horizonte-2026"
bash preparar_ssh.sh <usuario_admin>
stat -c '%a %n' /home/<usuario_admin>/.ssh /home/<usuario_admin>/.ssh/authorized_keys
ssh horizonte whoami
```

- id_ed25519 es la clave privada: no sale del cliente.
- id_ed25519.pub es la clave pública: se autoriza en authorized_keys del usuario.
- Permisos esperados: ~/.ssh = 700 y authorized_keys = 600, con propietario correcto.
- El alias Host horizonte debe definir HostName, User, IdentityFile e IdentitiesOnly yes.

3.6. Publicar con scp y cerrar Lab 10

```
scp comunicado.html horizonte:/srv/horizonte/www/
ssh horizonte "ls -l /srv/horizonte/www/comunicado.html"
bash telnet_laboratorio.sh desactivar
ss -tln | grep ':23 ' || echo "TELNET desactivado: puerto 23 cerrado"
bash verificar_lab10.sh <usuario_admin>
```

Criterio de cierre Lab 10
El verificador debe informar 11 de 11; TELNET queda desactivado; comunicado.html está publicado con propietario y grupo correctos.

- ☐ PCAP TELNET y captura Wireshark con contenido de prueba visible en claro.
- ☐ PCAP SSH y evidencia de que el contenido no se lee en claro.
- ☐ Huella del host regenerada y verificada.
- ☐ ssh horizonte funciona con clave ed25519 sin contraseña interactiva.
- ☐ comunicado.html se publicó mediante scp.
- ☐ TELNET quedó desactivado y el verificador mostró 11/11.
- ☐ HOJA_TRABAJO.md y BITACORA_IA.md completas.

4. Laboratorio 11 — SSH endurecido, SFTP, Fail2ban y túnel

Objetivo: endurecer SSH, limitar la cuenta comunicacion a SFTP, aplicar bloqueo de fuerza bruta con Fail2ban/nftables y acceder a una API interna mediante un túnel cifrado.

4.1. Preflight y dos sesiones

```
sudo -i
cd ~/lab11
ssh horizonte whoami
sshd -T | grep -E 'permitrootlogin|passwordauthentication|maxauthtries|loglevel'
```

No continúes si el acceso por clave del Lab 10 no funciona. Mantén dos sesiones abiertas durante los cambios.

4.2. Endurecer sshd

```
# /etc/ssh/sshd_config.d/10-horizonte.conf
PermitRootLogin no
PasswordAuthentication no
AuthenticationMethods publickey
AllowGroups sshadmins sftp-web
MaxAuthTries 3
LoginGraceTime 20
KexAlgorithms sntrup761x25519-sha512@openssh.com,curve25519-sha256
LogLevel VERBOSE
Banner /etc/issue.net

sshd -t
# Reinicia solo si sshd -t no informa errores:
systemctl restart ssh
sshd -T | grep -E 'permitrootlogin|passwordauthentication|maxauthtries|loglevel'
ssh horizonte whoami
```

Evita bloquearte

Si sshd -t muestra un error, corrige el archivo antes de reiniciar. Conserva la sesión administrativa abierta y confirma que ssh horizonte continúa funcionando.

4.3. SFTP enjaulado

```
Match Group sftp-web
    ChrootDirectory /srv/horizonte
    ForceCommand internal-sftp -d /www -u 0002
    AllowTcpForwarding no
    PermitTTY no
```

Ruta	Propietario/permisos	Función
/srv	root:root · 755	Ruta base.
/srv/horizonte	root:root · 755	Raíz del chroot; no debe ser escribible por la cuenta enjaulada.
/srv/horizonte/www	root:webadmin · 2775	Carpeta de publicación con grupo compartido.

```
sftp comunicacion@srv-horizonte
# Dentro de SFTP:
pwd
cd /etc
exit
ssh comunicacion@srv-horizonte
```

Resultado esperado: pwd muestra /www; cd /etc falla porque la ruta queda fuera de la jaula; SSH interactivo informa que solo se permiten conexiones SFTP.

4.4. Fail2ban: configuración y diagnóstico

La guía oficial de Lab 11 propone la configuración siguiente. Completa los TODO en fail2ban/horizonte-ssh.local y ejecuta endurecer_ssh.sh.

Configuración objetivo de la guía oficial Lab 11

```
[sshd]
enabled = true
mode = aggressive
journalmatch = _SYSTEMD_UNIT=ssh.service + _COMM=sshd
maxretry = 4
findtime = 10m
bantime = 1h
bantime.increment = true
```

```
fail2ban-client status sshd
fail2ban-client get sshd ignoreip
fail2ban-client get sshd journalmatch
fail2ban-client get sshd bantime
```

No mezclar configuraciones

En la guía oficial se documentan maxretry=4 y bantime=1h. En la demostración Docker verificada el 21/10/2026 se observó maxRetry=5, findtime=600 y banTime=600. Para repetir exactamente esa demostración usa los valores reales del contenedor; para entregar el laboratorio sigue los archivos y el verificador oficiales.

4.5. Prueba controlada de bloqueo en Docker

La demostración verificada utilizó tw1-seguridad-servidor (172.22.0.2) y tw1-cliente-fail2ban (172.22.0.3). Las IP pueden cambiar si se recrea la red; confírmalas antes de repetir.

```
docker ps --filter "name=tw1" --format "table {{.Names}}\t{{.Status}}"
docker exec tw1-seguridad-servidor fail2ban-client status sshd
docker exec tw1-seguridad-servidor bash -c "tail -n 30 /var/log/fail2ban.log"
docker exec tw1-seguridad-servidor nft list set inet f2b-table addr-set-sshd
```

```
# Un intento controlado desde el contenedor cliente:
docker exec tw1-cliente-fail2ban ssh -i /tmp/clave_prueba_fail2ban -o IdentitiesOnly=yes -o BatchMode=yes -o
ConnectTimeout=5 usuario_inexistente_tw1@172.22.0.2 exit
```

Repite únicamente el número de intentos que corresponda a maxretry en el entorno de práctica. Permission denied por sí solo no prueba el bloqueo. La evidencia válida combina el evento Ban, el estado del jail y la IP en nftables.

```
docker exec tw1-seguridad-servidor fail2ban-client status sshd
docker exec tw1-seguridad-servidor nft list set inet f2b-table addr-set-sshd
docker exec tw1-seguridad-servidor bash -c "grep -E 'Found|Ban |Unban|ERROR' /var/log/fail2ban.log | tail -n 20"
```

4.6. Expiración automática

Anota la hora UTC de Ban y espera el bantime completo. No uses unbanip durante esta evidencia: el objetivo es probar la expiración automática.

```
docker exec tw1-seguridad-servidor date -u '+%Y-%m-%d %H:%M:%S UTC'
docker exec tw1-seguridad-servidor fail2ban-client status sshd
docker exec tw1-seguridad-servidor bash -c "grep -E 'Ban 172\\.22\\.0\\.3|Unban 172\\.22\\.0\\.3' /var/log/fail2ban.log
| tail -n 5"
docker exec tw1-seguridad-servidor nft list set inet f2b-table addr-set-sshd
```

Resultado final esperado: Currently banned: 0, evento Unban para la IP de prueba y addr-set-sshd sin elementos. Si sigue bloqueada después del plazo, guarda hora UTC y registros y diagnostica; no borres reglas a ciegas.

4.7. Túnel SSH y verificador

```
# La guía del laboratorio usa el puerto publicado 2222 y el servicio interno 127.0.0.1:8081:
ssh -p 2222 -N -L 9081:127.0.0.1:8081 ana@localhost
# En otra terminal:
curl http://127.0.0.1:9081/eco

# Verificador dentro del servidor/laboratorio:
bash verificar_lab11.sh <usuario_admin>
```

Si el compose del curso publica otros puertos, sigue los valores de su archivo y hoja de trabajo. No expongas la API en una interfaz pública para evitar el túnel.

Criterio de cierre Lab 11
El verificador debe informar 15 de 15. La entrega debe mostrar SSH endurecido, SFTP restringido, Fail2ban con Ban en nftables, expiración automática y túnel /eco funcional.

- ☐ sshd -T confirma root y autenticación por contraseña deshabilitados.
- ☐ ssh horizonte continúa funcionando con clave.
- ☐ SFTP empieza en /www, no accede a /etc y no ofrece shell.
- ☐ Fail2ban detecta los intentos y aplica Ban.
- ☐ nftables contiene la IP durante el bloqueo.
- ☐ Tras esperar el bantime, aparece Unban, Currently banned: 0 y conjunto vacío.
- ☐ El túnel entrega respuesta /eco y el verificador muestra 15/15.
- ☐ HOJA_TRABAJO.md y BITACORA_IA.md completas.

5. Guardar evidencias desde PowerShell

```
New-Item -ItemType Directory -Force C:\TW1\evidencias\Actividad3 | Out-Null

docker exec tw1-seguridad-servidor fail2ban-client status sshd |
  Tee-Object -FilePath C:\TW1\evidencias\Actividad3\lab11_fail2ban_estado.txt

docker exec tw1-seguridad-servidor nft list set inet f2b-table addr-set-sshd |
  Tee-Object -FilePath C:\TW1\evidencias\Actividad3\lab11_nftables.txt

docker exec tw1-seguridad-servidor bash -c "grep -E 'Ban 172\\.22\\.0\\.3|Unban 172\\.22\\.0\\.3' /var/log/fail2ban.log
| tail -n 10" |
  Tee-Object -FilePath C:\TW1\evidencias\Actividad3\lab11_ban_unban.txt
```

6. Matriz de evidencias

ID	Archivo sugerido	Qué demuestra
A3-01	00_contenedores.txt / 00_entorno.png	Contenedores correctos y estado inicial.
A3-02	lab10_telnet_flujo.png	Datos de TELNET visibles en claro.
A3-03	lab10_ssh_flujo.png	SSH no expone la sesión en claro.
A3-04	lab10_ssh_scp.png	Clave ed25519, alias y archivo publicado.
A3-05	lab10_verificador_11de11.png	Verificador del Lab 10 aprobado.

ID	Archivo sugerido	Qué demuestra
A3-06	lab11_sshd_sftp.png	SSH endurecido y SFTP restringido.
A3-07	lab11_ban_nftables.png	Ban en log y IP dentro de nftables.
A3-08	lab11_unban_nftables.png	Unban automático y set vacío.
A3-09	lab11_tunel_eco.png	Respuesta del servicio interno por el túnel.
A3-10	lab11_verificador_15de15.png	Verificador del Lab 11 aprobado.
A3-11	HOJA_TRABAJO.md / BITACORA_IA.md	Reflexión y uso crítico de IA.

7. Plantilla de bitácora de IA

```
# BITACORA_IA.md — Actividad 3
Fecha:
Laboratorio:
Objetivo de la consulta:
Prompt (sin claves privadas ni datos sensibles):
Respuesta de IA:
Qué acepté / qué descarté:
Cambio realizado:
Prueba que demuestra el resultado:
Evidencia guardada:
Qué aprendí:
Riesgo si aceptaba la respuesta sin verificar:
```

8. Preguntas para defensa oral

- ¿Por qué TELNET expone datos y SSH no?
- ¿Cuál es la diferencia entre clave privada, clave pública y known_hosts?
- ¿Por qué se debe verificar una huella de host cambiada?
- ¿Por qué la raíz del chroot debe pertenecer a root?
- ¿Qué significan maxretry, findtime y bantime?
- ¿Por qué Permission denied no basta para demostrar que Fail2ban bloqueó?
- ¿Qué evidencias prueban Ban, aplicación en nftables y expiración automática?
- ¿Qué ventaja tiene un túnel si la API escucha solo en 127.0.0.1?

9. Definición de terminado

Actividad 3 terminada cuando…

Lab 10: 11/11, TELNET apagado, capturas comparativas, clave ed25519 y scp. Lab 11: 15/15, SSH endurecido, SFTP restringido, Ban/Unban automático en nftables, túnel /eco, hojas y bitácoras. Todas las capturas deben ser reales, legibles y corresponder a la ejecución del estudiante.